

International University

School of Computer Science and Engineering

Web Application Development

Laboratory

IT093IU

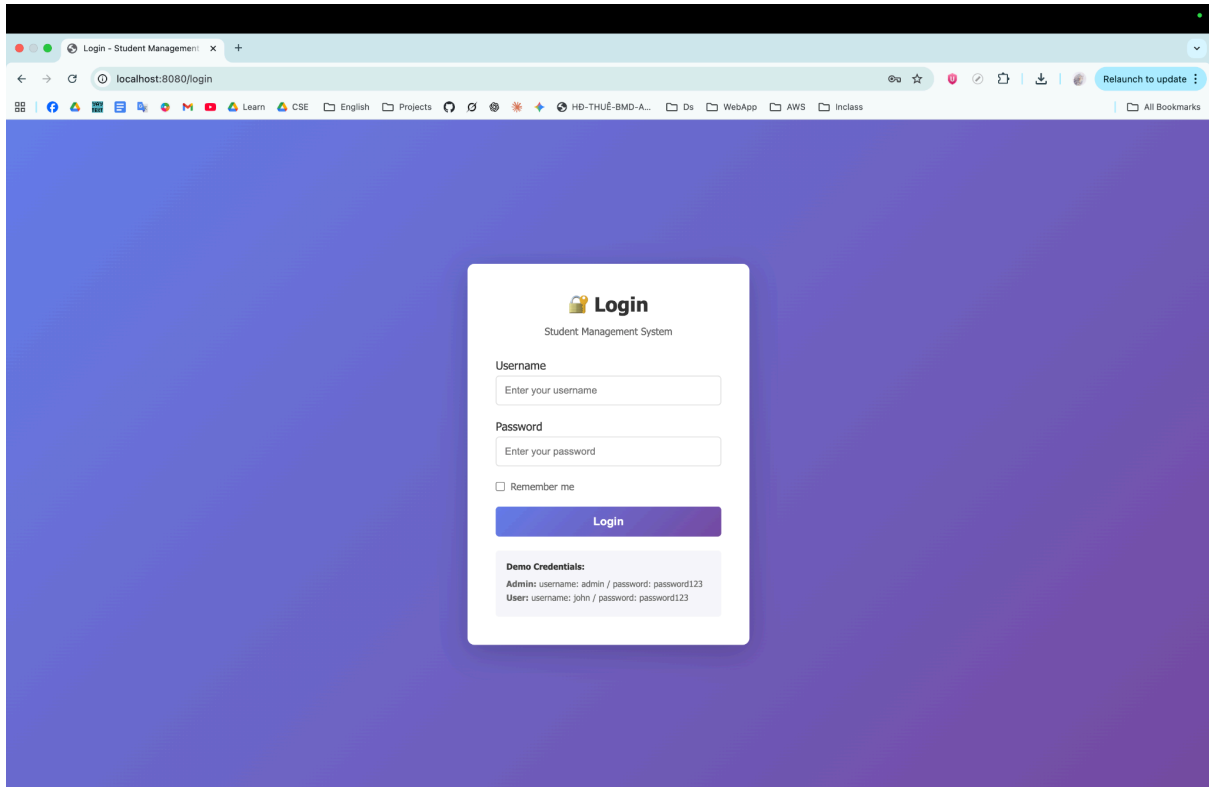
Lab #6

Submitted by

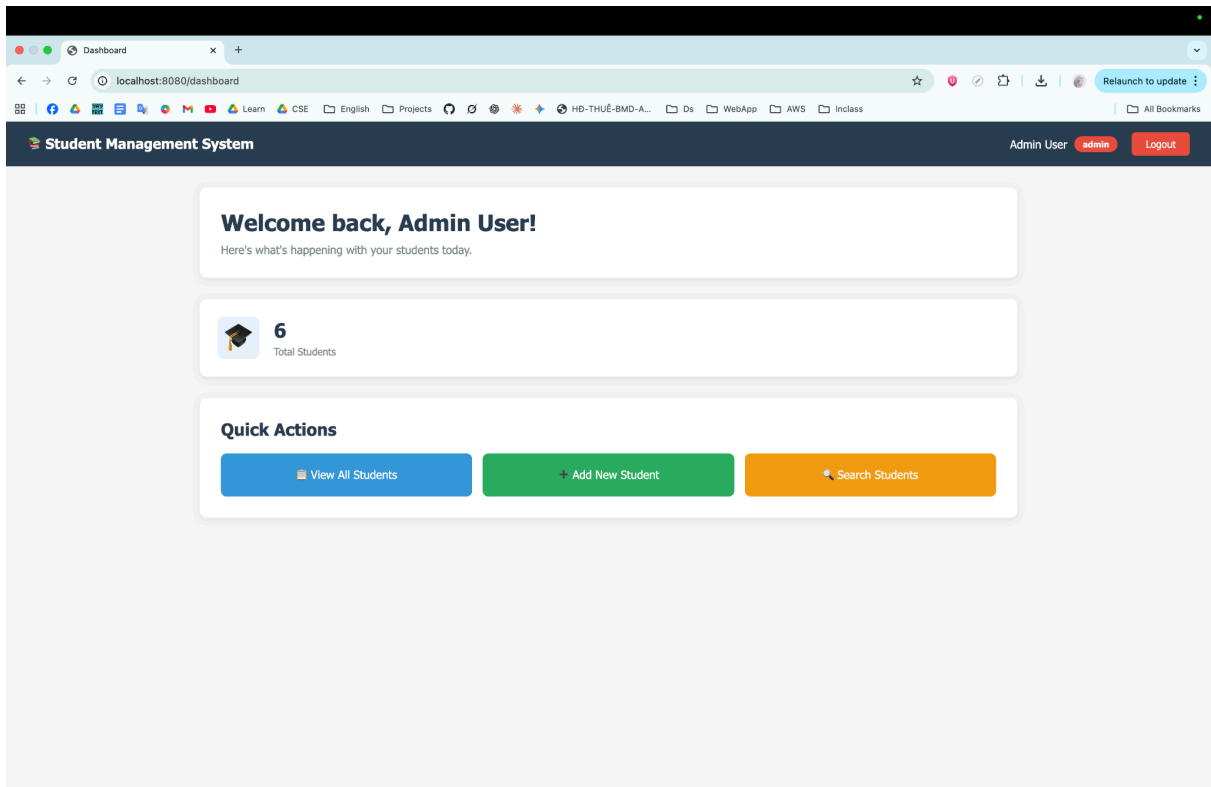
Nguyễn Hồng Ngọc Hân - ITCSIU22229

EXERCISE 5: AUTHENTICATION FILTER

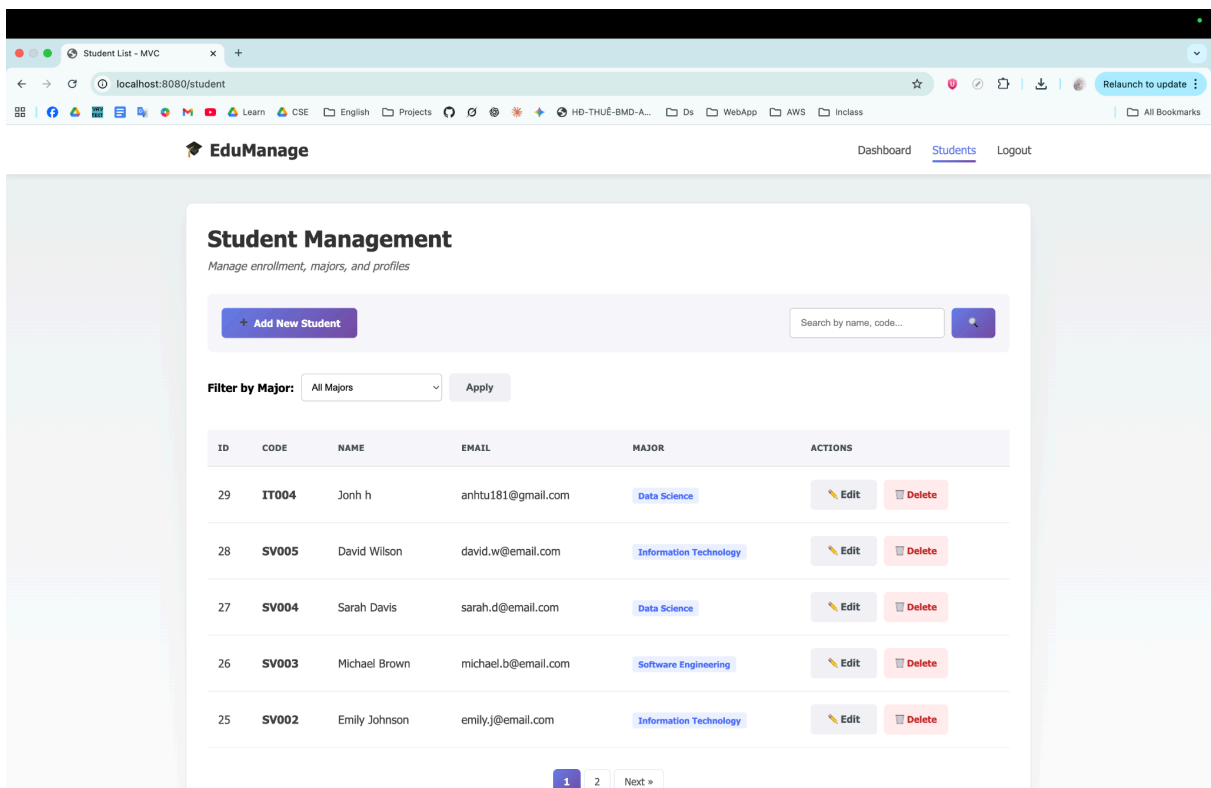
- **Test cases:**
 - + **Deploy application**
 - + **Access the student page without login:**



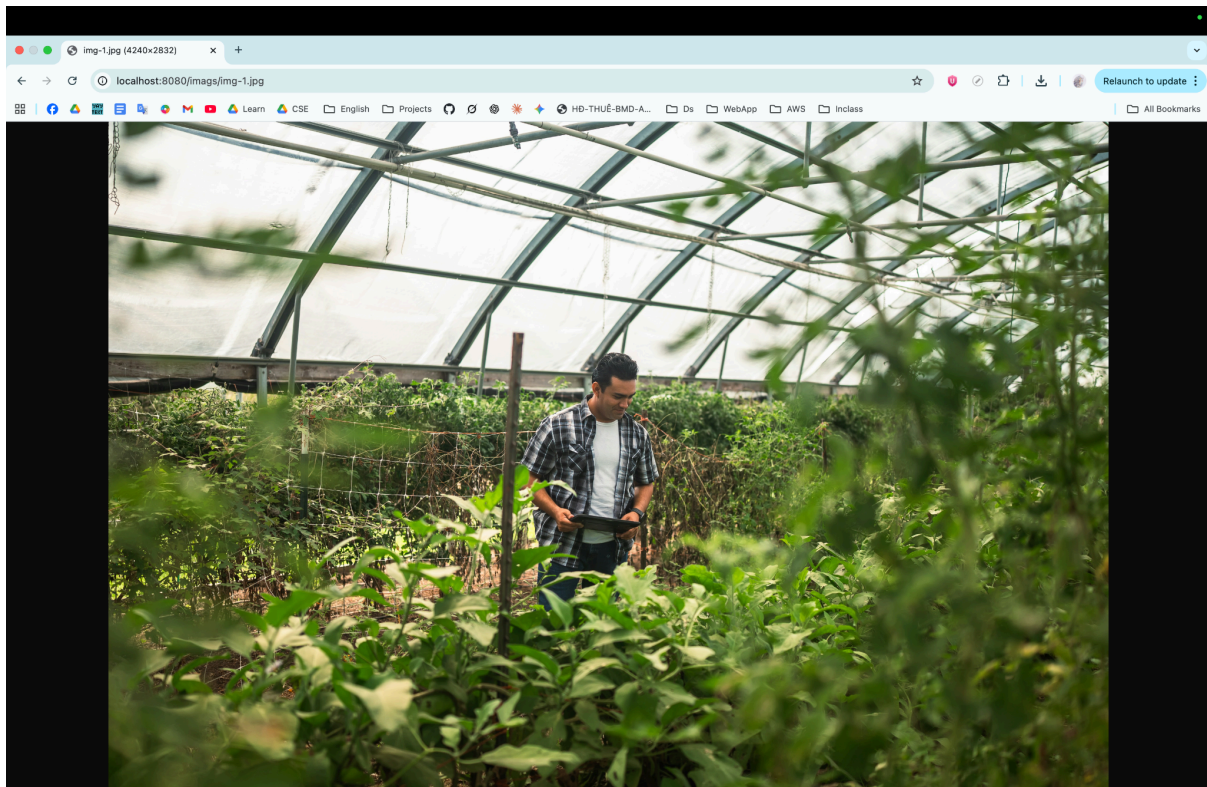
- + **Login successfully**



+ Access /student → Should work



+ Access static files (CSS, images) → Should work without login



Explain:

The AuthFilter acts like a security guard for your website. It intercepts every incoming request (`/*`) and checks whether the user has permission to access the requested page.

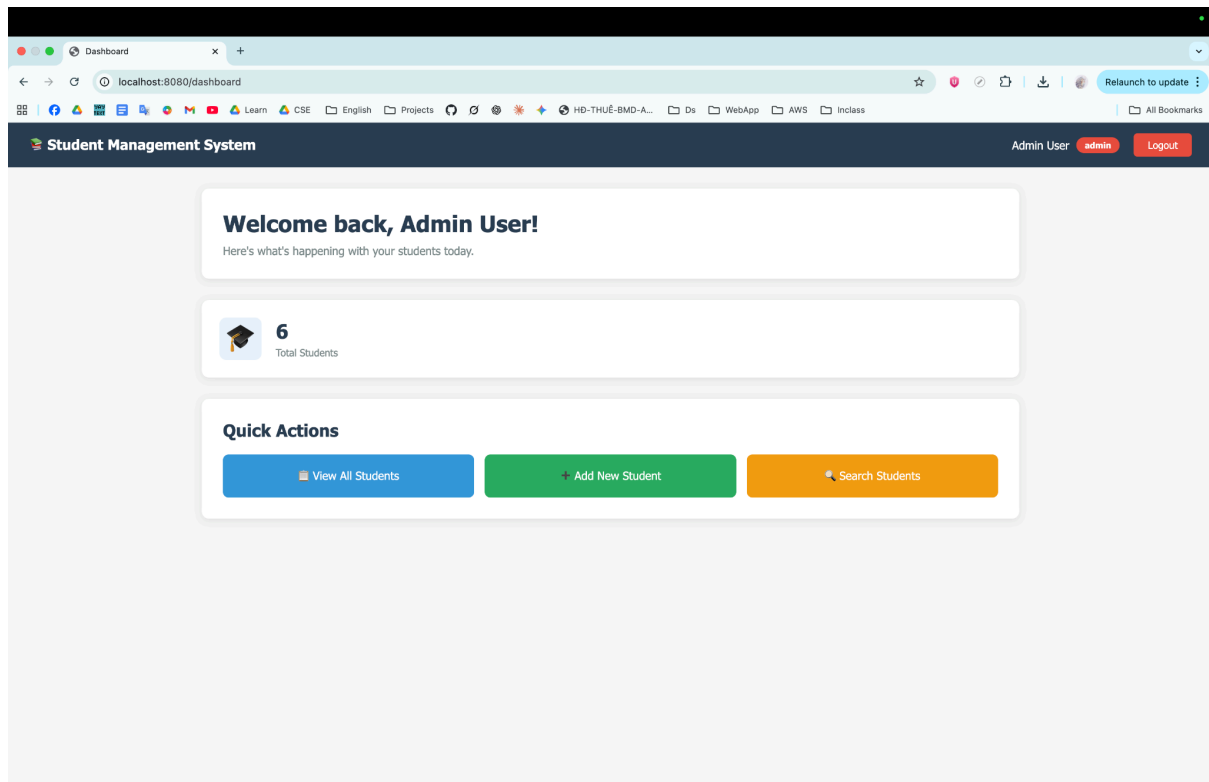
The filter uses `PUBLIC_URLS` together with the `isPublicUrl` method as a whitelist of pages that do not require authentication—such as the login page or static resources like CSS, JavaScript, and images. The `isPublicUrl` function simply checks whether the requested path is included in this list of publicly accessible routes.

The main logic happens inside `doFilter`. First, it determines the path being requested. Next, it checks whether this path is in the whitelist. If it is, the filter immediately allows the request to continue by calling `chain.doFilter()`. If the path is not public, the filter then checks the user's session. If a valid session exists and contains a "user" attribute—indicating that the user has already logged in—the request is allowed to proceed. Otherwise, the filter blocks access and redirects the user to the `/login` page.

Finally, the init and destroy methods handle simple setup and cleanup tasks. In your current implementation, they only print messages to the console when the server starts or shuts down.

EXERCISE 6: ADMIN AUTHORIZATION FILTER

- **Testing:**
 - + **Login as admin → Try edit/delete → Should work**



Browser: Edit Student
URL: localhost:8080/student?action=edit&id=29

Edit Student

Student Code *
IT004
Format: 2 letters + 3+ digits

Full Name *
Jonh

Email *
Jonh h
anhthu181@gmail.com

Major *
Data Science

[Update Student](#) [Cancel](#)

Browser: Student List - MVC
URL: localhost:8080/student?action=list&message=Student%20updated%20successfully

localhost:8080 says
Are you sure you want to delete this student?

[Cancel](#) [OK](#)

EduManage

Student Management
Manage enrollment, majors, and profiles

Student updated successfully

[Add New Student](#)

Filter by Major: All Majors [Apply](#)

ID	CODE	NAME	EMAIL	MAJOR	ACTIONS
29	IT004	Jonh	anhthu181@gmail.com	Data Science	Edit Delete
28	SV005	David Wilson	david.w@email.com	Information Technology	Edit Delete
27	SV004	Sarah Davis	sarah.d@email.com	Data Science	Edit Delete
26	SV003	Michael Brown	michael.b@email.com	Software Engineering	Edit Delete
25	SV002	Emily Johnson	emily.j@email.com	Information Technology	Edit Delete

Student List - MVC

localhost:8080/student?action=list&message=Student%20updated%20successfully

Relaunch to update

EduManage

DashboardStudentsLogout

Student Management

Manage enrollment, majors, and profiles

Student updated successfully

Add New Student

Search by name, code...

Filter by Major:

All Majors

Apply

ID	CODE	NAME	EMAIL	MAJOR	ACTIONS
29	IT004	Jonh	anhtu181@gmail.com	Data Science	Edit Delete
28	SV005	David Wilson	david.w@email.com	Information Technology	Edit Delete
27	SV004	Sarah Davis	sarah.d@email.com	Data Science	Edit Delete
26	SV003	Michael Brown	michael.b@email.com	Software Engineering	Edit Delete
25	SV002	Emily Johnson	emily.j@email.com	Information Technology	Edit Delete

Student List - MVC

localhost:8080/student?action=list&message=Student%20deleted%20successfully

Relaunch to update

EduManage

DashboardStudentsLogout

Student Management

Manage enrollment, majors, and profiles

Student deleted successfully

Add New Student

Search by name, code...

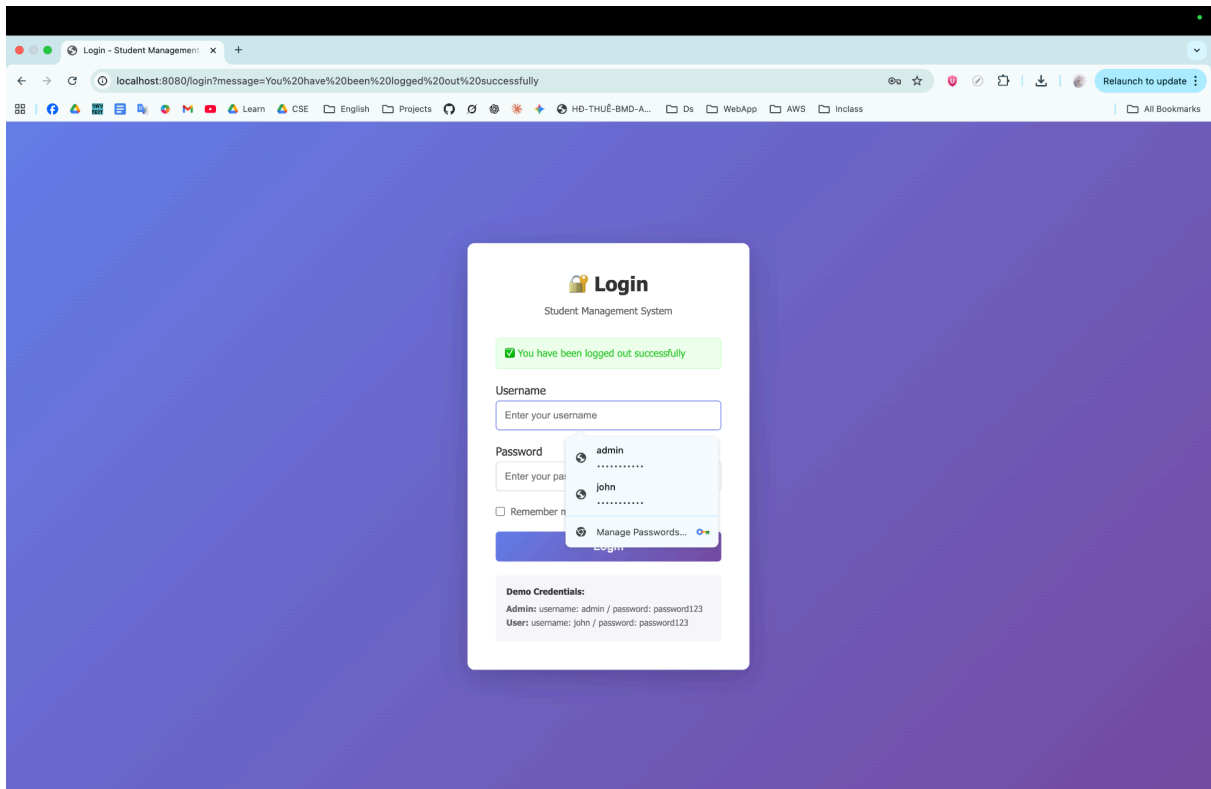
Filter by Major:

All Majors

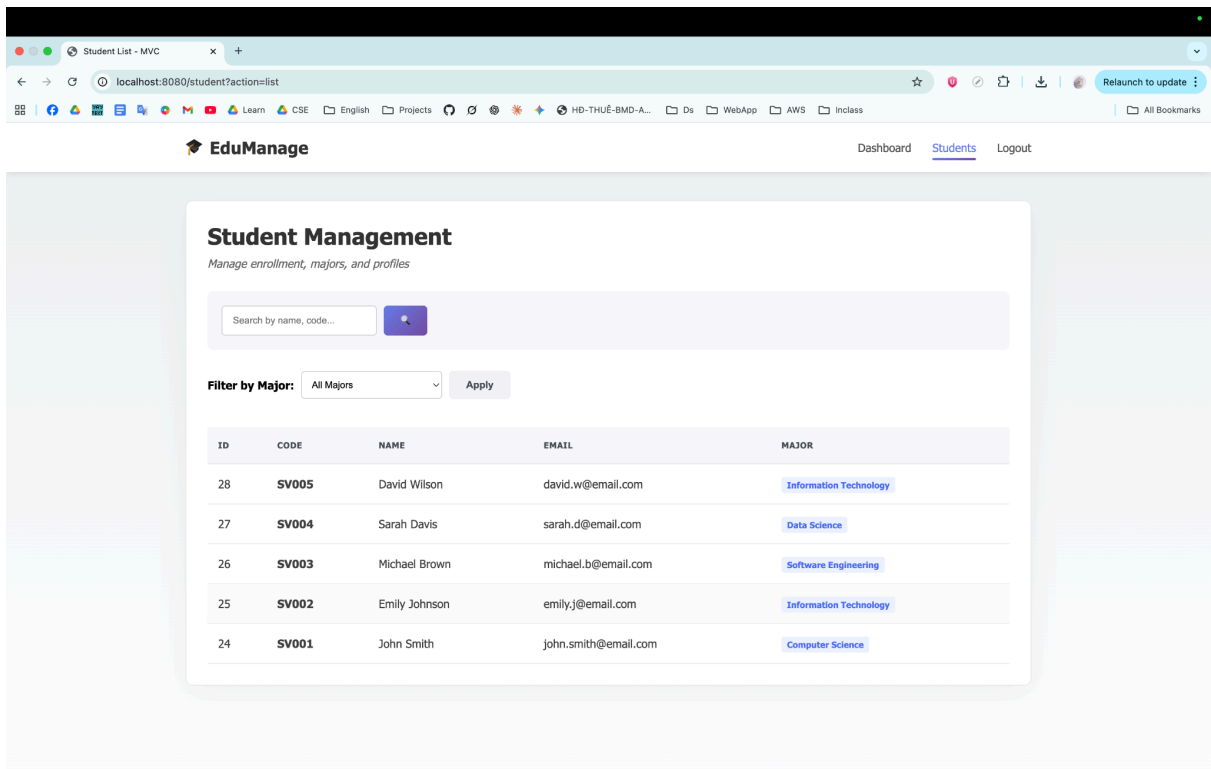
Apply

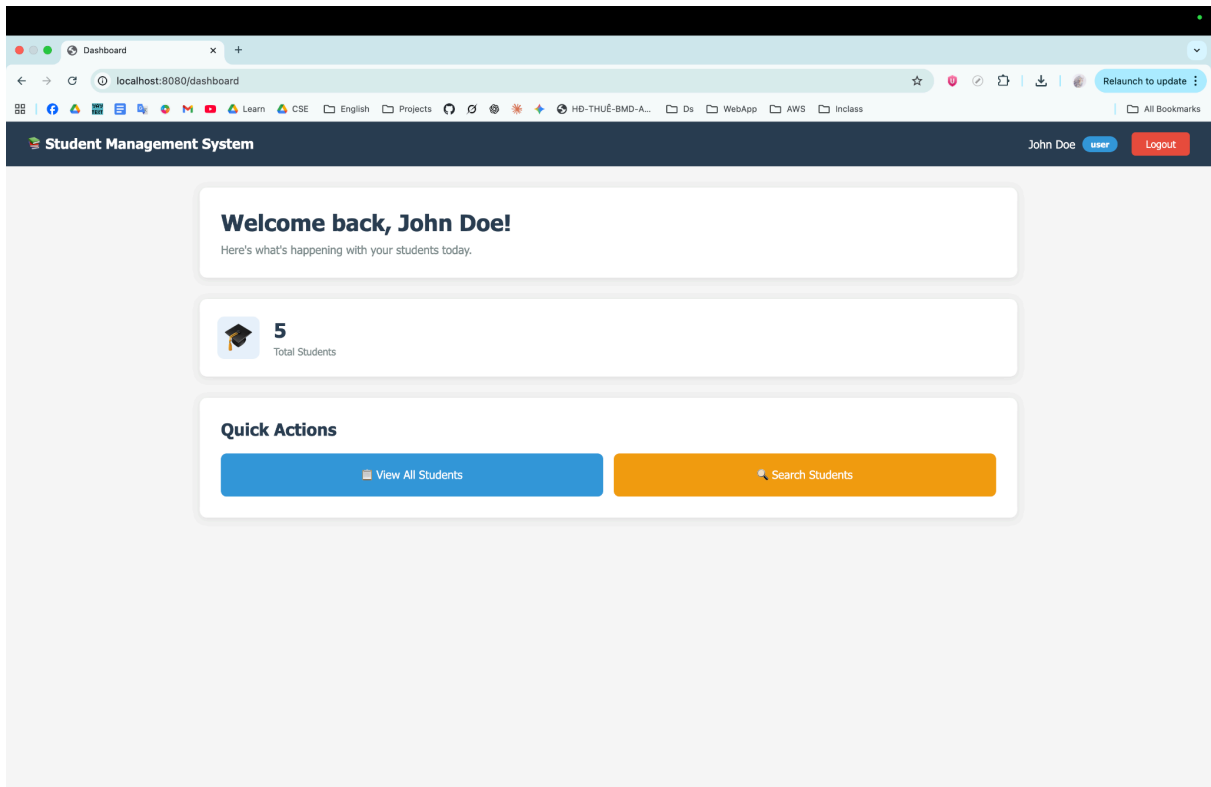
ID	CODE	NAME	EMAIL	MAJOR	ACTIONS
28	SV005	David Wilson	david.w@email.com	Information Technology	Edit Delete
27	SV004	Sarah Davis	sarah.d@email.com	Data Science	Edit Delete
26	SV003	Michael Brown	michael.b@email.com	Software Engineering	Edit Delete
25	SV002	Emily Johnson	emily.j@email.com	Information Technology	Edit Delete
24	SV001	John Smith	john.smith@email.com	Computer Science	Edit Delete

+ Logout

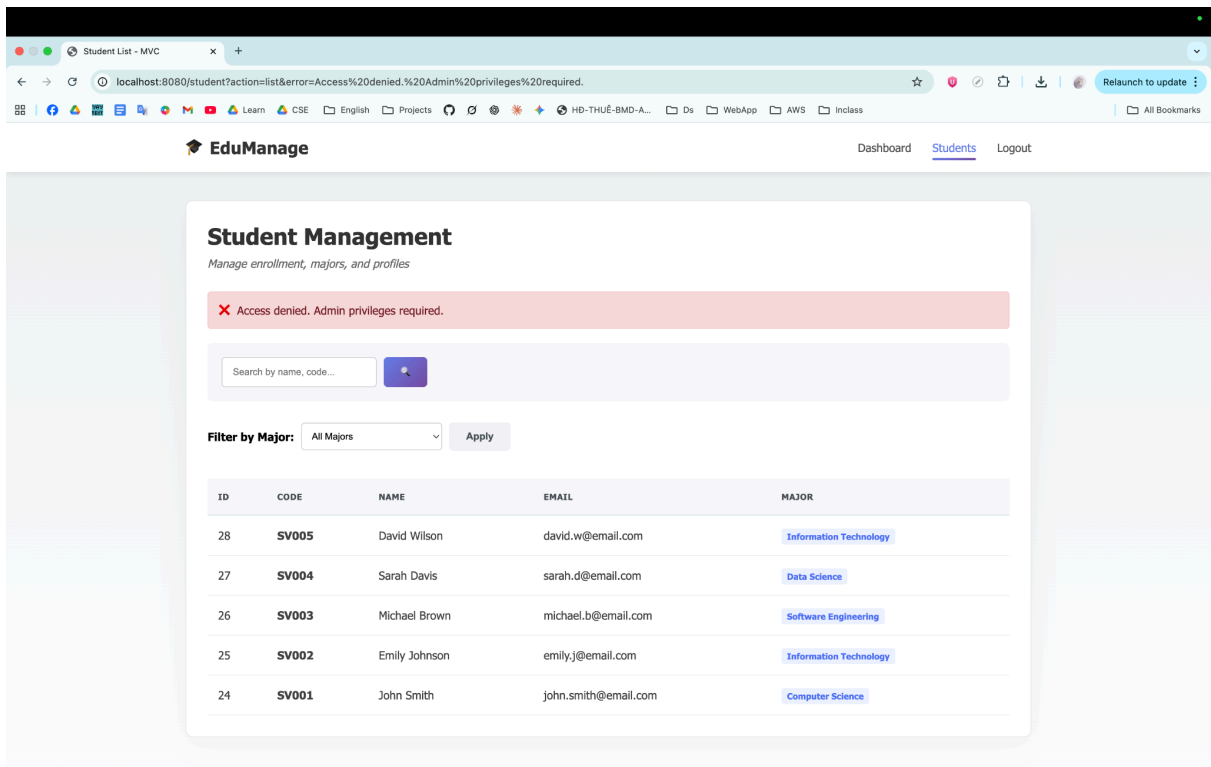


+ Login as regular user → Try edit/delete → Should be blocked





+ Try direct URL: `/student?action=delete&id=1` →
Should be blocked



Explain:

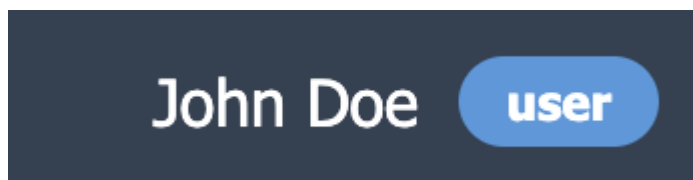
On the student page, an admin can see the actions column and has full access to features such as adding new students in the dashboard, while regular users or students cannot see the actions column and do not have permission to add new students. The filter uses an `ADMIN_ACTIONS` list—also known as the “danger list”—which contains all actions that can modify the database, including new, insert, edit, update, and delete. In the `doFilter` method, the filter first reads the action parameter from the URL. It then checks whether this action belongs to the danger list. If the action is safe (such as list or search), the request is allowed to continue normally so that regular users can view data. If the action is restricted, the filter checks the session to retrieve the current user and calls `user.isAdmin()`. If the user is an admin, the request continues; otherwise, the filter blocks the operation and redirects the user back to the list page with an “Access denied” message.

EXERCISE 7: ROLE-BASED UI

- Add navigation bar with user info



- Show role badge



- Hide "Add Student" button for non-admins
- Hide Edit/Delete buttons for non-admin

Student List - MVC

localhost:8080/student

EduManage

Dashboard [Students](#) Logout

Student Management

Manage enrollment, majors, and profiles

Search by name, code...

Filter by Major: All Majors Apply

ID	CODE	NAME	EMAIL	MAJOR
28	SV005	David Wilson	david.w@email.com	Information Technology
27	SV004	Sarah Davis	sarah.d@email.com	Data Science
26	SV003	Michael Brown	michael.b@email.com	Software Engineering
25	SV002	Emily Johnson	emily.j@email.com	Information Technology
24	SV001	John Smith	john.smith@email.com	Computer Science

- Show error messages from AdminFilter

✗ Access denied. Admin privileges required.